

Security+ 1.4 · Certificates

Master CyberSec — Official CompTIA Security+ (SY0-701) Comprehensive Study Guide · **Lesson 1.4** —
Certificates (14:38) · [Official YouTube Video ↗](#) · [Professor Messer Study Hub ↗](#)

Executive Lesson Summary: A digital certificate is a file signed by a Certificate Authority (CA) that binds a domain to a public key. Self-signed certificates are signed by the entity itself and should not be used publicly. A CSR (Certificate Signing Request) is sent to the CA containing the public key and identity. Revocation is checked via CRL (list), OCSP (online query), or OCSP stapling (server attaches response).

High-Yield Core Concepts Tested on Exam

- CA signs the certificate — trust chain: root CA → intermediate → leaf
- CSR contains the public key and identity, submitted to the CA for signing
- CRL, OCSP, and OCSP stapling are methods for checking certificate revocation
- Self-signed certificates are not trusted by public browsers
- Certificate binds a public key to an identity (e.g., domain name)

Exam Tips & Classic Scenarios

- 'contains public key and identity, signed by CA' = digital certificate
- 'revocation checking method with online query' = OCSP
- 'server attaches a timestamped OCSP response' = OCSP stapling
- Browser warning about untrusted certificate = self-signed, expired, or revoked

Typical Exam Scenario: Scenario: 'A user visits a site and the browser shows a red padlock indicating the certificate is not trusted' — self-signed, expired, or revoked certificate.

Beyond the Video: Official CompTIA Exam Concepts, Protocols & Traps (Lesson 1.4 — Certificates)

Why is this advanced coverage required for SY0-701? Video overviews provide foundational familiarity, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

- **Principle of Least Privilege:** Users and computational entities must be granted only the minimum permissions strictly required to perform designated tasks.
- **Defense-in-Depth (Layered Security):** Application of multiple security controls (technical, administrative, physical) to prevent single-point perimeter compromise.

Classic CompTIA Traps & Question Framing:

- Avoid rote memorization: CompTIA exam prompts regularly adjust technical constraints requiring you to defend why one valid security control is the *MOST appropriate* or *FIRST step*.
- Scrutinize question qualifiers: 'without additional licensing costs' favors native OS tools; 'granular administrative command accounting' favors TACACS+ over RADIUS; 'non-repudiation' mandates asymmetric private key signing.

Practice Questions with In-Depth Solutions (10 Questions)

Detailed answer key with step-by-step technical rationale and comprehensive distractor breakdown provided below. Attempt answering independently first.

1. In TLS/HTTPS, the website's certificate serves to:

- A)** Prove the server's identity and enable secure key exchange
- B)** Encrypt the disk
- C)** Block malware
- D)** Perform backup

2. In a PKI infrastructure, which component is responsible for validating and revoking digital certificates?

- A)** RA (Registration Authority)
- B)** CA (Certificate Authority)
- C)** CRL (Certificate Revocation List)
- D)** OCSP (Online Certificate Status Protocol)

3. A characteristic of HASH (unlike encryption) is that it:

- A)** Can be reversed with the key
- B)** Is one-way (not reversible)
- C)** Always shortens the text by half
- D)** Requires a key pair

4. Which type of encryption uses public and private key pairs?

- A)** Hashing
- B)** Symmetric encryption
- C)** Asymmetric encryption
- D)** Steganography

5. Corporate scenario (Certificates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'CA signs the certificate — chain of trust root CA → intermediate → leaf'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: CA signs the certificate — chain of trust root CA → intermediate → leaf...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

6. Corporate scenario (Certificates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'CSR = certificate signing request: contains the public key + identity'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: CSR = certificate signing request: contains the public key + identity...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

7. Corporate scenario (Certificates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'CRL/OCSP/stapling = how the browser checks if a certificate has been revoked'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: CRL/OCSP/stapling = how the browser checks if a certificate has been revoked...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

8. Corporate scenario (Certificates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: '"contains public key and identity, signed by CA' = certificate'. What is the best recommendation or applicable control classification?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: 'contains public key and identity, signed by CA' = certificate...
- D)** Allow shared access among administrators using generic credentials

9. Corporate scenario (Certificates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'revocation checking method with online query' = OCSP'. What is the best recommendation or applicable control classification?

- A)** Implement the corresponding solution: 'revocation checking method with online query' = OCSP...
- B)** Temporarily disable audit logs to accelerate system throughput
- C)** Replace preventive technical controls with informal terms of adherence
- D)** Allow shared access among administrators using generic credentials

10. Corporate scenario (Certificates): During a security review and compliance audit aligned with the CompTIA Security+ exam (SY0-701, Section 1.4), an analyst evaluates the following technical requirement: 'Scenario: 'user accesses the site and the red padlock says the certificate is untrusted' — self-signed or expired/revoked.'. What is the best recommendation or classification of applicable control?

- A)** Temporarily disable audit logs to accelerate system throughput
- B)** Replace preventive technical controls with informal terms of adherence
- C)** Implement the corresponding solution: Scenario: 'user accesses the site and the red padlock says the certificate ...
- D)** Allow shared access among administrators with generic credentials

COMPREHENSIVE ANSWER KEY & DISTRACTOR BREAKDOWN

1) A — Prove the server's identity and enable secure key exchange.

✓ **Why it's correct:** In TLS/HTTPS, the server's digital certificate (X.509) serves two critical functions: (1) authenticate the server's identity to the client, as it is issued by a trusted Certificate Authority (CA) that digitally signs the server's public key, binding it to the domain name; (2) enable secure key exchange, as the public key contained in the certificate is used by the client to encrypt the pre-master secret (or to verify signatures in ephemeral Diffie-Hellman), allowing both parties to derive symmetric session keys without transmitting them in clear. Without the certificate, the client would have no guarantee of talking to the legitimate server and could not establish a confidential authenticated channel.

✗ **Why the others are wrong:**

- *Encrypt the disk:* Disk encryption (e.g., BitLocker, LUKS, FileVault) is a data-at-rest protection technique that encrypts sectors of physical storage to prevent unauthorized reading if the device is lost or stolen. It operates at the storage layer, not the transport layer. The TLS/HTTPS certificate acts exclusively at the session/presentation layer to protect data in transit between client and server; it has no relation to encrypting local or remote volumes.
- *Block malware:* Malware blocking is performed by endpoint security solutions (EDR, antivirus), email gateways, content proxies, and intrusion detection systems, which inspect files, traffic, and behaviors for malicious signatures or anomalies. A TLS certificate only proves the server's identity and establishes an encrypted channel; it does not analyze traffic content or prevent execution of malicious code. A malicious website can perfectly have a valid TLS certificate, as the CA only validates domain control, not content intent.
- *Perform backup:* Backup is the process of copying and storing data in a secondary location for recovery after loss, corruption, or disaster. It involves retention policies, scheduling, and restoration testing. The TLS certificate does not execute, schedule, or manage data copies; its function is strictly cryptographic and authentication during the TLS handshake. Confusing a certificate with a backup mechanism completely ignores the purpose of public key infrastructure (PKI) in the context of communications security.

2) B — CA (Certificate Authority).

✓ **Why it's correct:** The **CA (Certificate Authority)** is the central component of a PKI responsible for issuing, validating, and revoking digital certificates. It digitally signs certificates, ensuring the authenticity and integrity of public keys. Additionally, the CA maintains and publishes the CRL (Certificate Revocation List) and/or provides the OCSP (Online Certificate Status Protocol) service so that third parties can verify whether a certificate is still valid. In the CompTIA Security+ (SY0-701) syllabus, the CA is described as the trusted entity that validates identities and manages the certificate lifecycle, including revocation. Therefore, the CA is the exact answer for 'validating and revoking digital certificates'.

✗ **Why the others are wrong:**

- *RA (Registration Authority):* The RA (Registration Authority) is an entity subordinate to the CA that acts as an intermediary in the user registration process. Its main function is to verify the identity of the requester before forwarding the certificate request to the CA, but it does not issue, validate, or revoke certificates. The RA may assist in collecting documentation and initial authentication, but the final decision to issue and revoke is always the CA's. In the context of the question, the RA does not perform certificate validation and revocation; it only facilitates registration, so it is incorrect.
- *CRL (Certificate Revocation List):* The CRL is a list periodically published by the CA containing the

serial numbers of certificates that have been revoked before their expiration date. It is a lookup mechanism to check whether a certificate is revoked, but it does not perform validation or revocation itself. The CRL is an artifact generated by the CA; it does not make decisions or execute revocation actions. Furthermore, validating a certificate involves verifying the CA's signature, the chain of trust, and temporal validity, which is not done by the CRL. Therefore, CRL is only a lookup tool, not the component responsible for validation and revocation.

- **OCSP (Online Certificate Status Protocol):** OCSP is a real-time query protocol that allows checking whether a specific certificate has been revoked by querying the CA or an OCSP responder directly. It offers a faster alternative to the CRL, but it is not the component that validates or revokes certificates; it is only a status-checking service. The responsibility for issuing, validating, and revoking certificates remains with the CA. OCSP depends on the CA to obtain revocation information. Thus, it is not the correct answer for the function of validating and revoking certificates.

3) B — Is one-way (not reversible).

✓ **Why it is correct:** A fundamental characteristic of cryptographic hash functions is that they are one-way, i.e., not reversible. This means that from the hash, it is not possible to recover the original message. This property is known as pre-image resistance. Unlike encryption, which is reversible with the correct key, hashing is designed to be irreversible. CompTIA Security+ highlights that hash functions like SHA-256 are used for integrity and password storage (with salt), precisely because they cannot be reversed. The option 'Is one-way (not reversible)' correctly describes this essential characteristic.

✗ Why the others are wrong:

- *Can be reversed with the key:* This is a characteristic of symmetric or asymmetric encryption, not hash functions. In encryption, reversal is possible with the appropriate key (symmetric) or with the private key (asymmetric). Hash functions have no key and are not designed for reversal. Therefore, this statement is incorrect for hash. CompTIA Security+ emphasizes that hash is one-way and does not use keys, unlike cipher.
- *Always shortens the text by half:* Hash functions produce a fixed-size output regardless of input size. For example, SHA-256 always generates 256 bits (32 bytes). There is no 'shorten by half' rule; the digest size is constant and defined by the algorithm. Moreover, the hash function is not simple compression; it must be resistant to collisions and pre-image. This statement is technically false and does not describe a hash property.
- *Requires a key pair:* Hash functions do not use keys. They are public and deterministic algorithms that map input data to a digest. The use of a key pair is characteristic of asymmetric encryption (such as RSA or ECC), not hash. Although hashes can be used together with keys in HMAC, the hash function itself does not require keys. Therefore, this option is incorrect.

4) C — Asymmetric encryption.

✓ **Why it is correct:** The correct answer is 'Asymmetric encryption'. Asymmetric encryption, also called public-key cryptography, uses a mathematically related key pair: a public key, which can be freely distributed, and a private key, kept secret by the owner. The public key is used to encrypt data or verify digital signatures, while the private key is used to decrypt or sign. Examples include RSA, ECC, and Diffie-Hellman. CompTIA Security+ requires understanding that asymmetry solves the key distribution problem and provides confidentiality, integrity, authentication, and non-repudiation.

✗ Why the others are wrong:

- *Hashing:* Hashing is a one-way cryptographic function that transforms an input of variable length into a fixed-length output (digest). It does not use keys and is not used to encrypt/decrypt data,

but rather to verify integrity. This option is incorrect because hashing does not involve key pairs and does not provide confidentiality.

- *Symmetric encryption*: Symmetric encryption uses a single shared secret key between parties to encrypt and decrypt. Examples: AES, DES, 3DES. Although efficient, it does not use a public and private key pair. This option is incorrect because it describes the single-key model, not the asymmetric model.
- *Steganography*: Steganography is the art of hiding information within other files (images, audio, video) so that the existence of the message goes unnoticed. It does not involve public or private key cryptography. This option is incorrect because it is not a key-based cryptographic method, but rather a concealment technique.

5) A — Implement the corresponding solution: CA signs the certificate — chain of trust root CA → intermediate → leaf...

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Certificates): CA signs the certificate — chain of trust root CA → intermediate → leaf. This describes the public key infrastructure (PKI) hierarchy where a root CA issues certificates to intermediate CAs, which in turn issue leaf (end-entity) certificates, establishing a verifiable chain of trust.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials*: Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

6) A — Implement the corresponding solution: CSR = certificate signing request: contains the public key + identity....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Certificates): CSR = certificate signing request: contains the public key + identity. A CSR is a block of encoded text given to a certificate authority (CA) when applying for a digital certificate. It contains the public key and identifying information (such as domain name, organization, etc.) but not the private key. The CA validates the identity and issues a signed certificate.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput*: This directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence*: Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials*: This destroys individual accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

7) A — Implement the corresponding solution: CRL/OCSP/stapling = how the browser checks if a certificate has been revoked....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Certificates): CRL/OCSP/stapling = how the browser checks if a certificate has been revoked.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and violates compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who made critical changes or malicious commands.

8) C — Implement the corresponding solution: 'contains public key and identity, signed by CA' = certificate....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Certificates): 'contains public key and identity, signed by CA' = certificate. A digital certificate binds a public key to an identity and is digitally signed by a Certificate Authority (CA) to ensure authenticity.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or runtime malware.
- *Allow shared access among administrators using generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.

9) A — Implement the corresponding solution: 'revocation checking method with online query' = OCSP....

✓ **Why it is correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Certificates): 'revocation checking method with online query' = OCSP. Online Certificate Status Protocol (OCSP) is a method for checking the revocation status of a digital certificate by querying an OCSP responder in real-time. It is an alternative to Certificate Revocation Lists (CRLs). The appropriate action is to implement the corresponding solution.

✗ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detecting incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls that rely solely on user behavior and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators using generic credentials:* Destroys individual

accountability and non-repudiation. It makes it impossible to prove who performed critical changes or malicious commands.

10) C — Implement the corresponding solution: Scenario: 'user accesses the site and the red padlock says the certificate

✅ **Why it's correct:** According to the official CompTIA Security+ (SY0-701) exam objectives for lesson 1.4 (Certificates): Scenario: 'user accesses the site and the red padlock says the certificate is untrusted' — self-signed or expired/revoked.

❌ **Why the others are wrong:**

- *Temporarily disable audit logs to accelerate system throughput:* Directly violates the Accounting pillar and forensic traceability. Without logs, the team is blind to detect incidents and breaks compliance standards (PCI DSS, ISO 27001).
- *Replace preventive technical controls with informal terms of adherence:* Informal terms are administrative controls, rely solely on user conduct, and do not block automated attacks, injections, or malware at runtime.
- *Allow shared access among administrators with generic credentials:* Destroys individual accountability and non-repudiation. Makes it impossible to prove who performed critical changes or malicious commands.